

TECHWAVES EGY

Blue Team Application Security & Defensive Engineering

Email: info@techwaves-egy.com | Web: www.techwaves-egy.com

CLASSIFICATION: STRICTLY CONFIDENTIAL // SECURITY AUDIT



Application: Enterprise Web Application

Environment: Staging

Mode: White Box / SAST & DAST

Date: 2026-08-24

Phase 1: Pre-Fix Security Assessment Report

OVERALL APPLICATION SECURITY POSTURE

6.2 / 10.0
MODERATE RISK

1. Executive Summary

Techwaves EGY conducted an internal Application Security Assessment evaluating authentication, authorization boundaries (IDOR/BOLA), input validation, injection defenses, cryptography, API workflow integrity, and SOC detection readiness across 11 security domains. The assessment identified key vulnerabilities requiring immediate remediation prior to production deployment.

2. 11-Domain Security Scorecard

#	Security Domain	Score	Rating	Primary Observation
1	Authentication & Session Security	8.0/10	Compliant	MFA active; token lifetime needs shortening.
2	Authorization, RBAC & Tenant Isolation (IDOR)	3.0/10	High Risk	Missing object ownership check on API endpoints.
3	Input Validation & Injection Defenses	4.5/10	High Risk	Dynamic query concatenation identified in search.
4	Output Encoding & XSS Defenses	9.0/10	Hardened	React auto-encoding; strict CSP active.
5	API & Business Logic Integrity	6.0/10	Moderate	Mass assignment on user update DTO.
6	State-Changing Security & CSRF	8.0/10	Compliant	SameSite=Strict cookies active.
7	SSRF & Perimeter Defenses	5.0/10	Moderate	Webhook endpoint lacks RFC 1918 block.
8	File Upload, Path Traversal & Storage	7.5/10	Compliant	S3 isolated storage; needs magic-byte check.
9	Cryptography, Secrets & Config Hygiene	6.5/10	Moderate	TLS 1.3 active; API key template committed.
10	Logging, Auditing & SOC Telemetry	4.0/10	High Risk	Missing failed auth logging & correlation ID.
11	Software Supply Chain & SCA (CVEs)	7.0/10	Compliant	Dependencies reviewed against live CVE library.

3. Detailed Vulnerability Dockets

[APP-001] Insecure Direct Object Reference (IDOR) on Order Retrieval

HIGH (CVSS 8.6)

Endpoint: GET /api/v1/orders/{orderId}

CWE: CWE-639

Vector:

CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Description: The order retrieval endpoint queries the database by order ID without validating that the requesting authenticated user owns the object or belongs to the authorized tenant.

Proof of Concept Trace:

GET /api/v1/orders/5002 HTTP/1.1

Host: app.internal

Authorization: Bearer

HTTP/1.1 200 OK -> UserB order data returned

Defensive Remediation Code:

```
// VULNERABLE
```

```
var order = await _context.Orders.FindAsync(id);
```

```
// SECURE
```

```
var userId = _currentUser.GetUserId();
```

```
var order = await _context.Orders.FirstOrDefault(o => o.Id == id && o.UserId == userId);
```

SOC Detection Rule (Sigma):

title: Suspicious Multi-Order IDOR Enumeration

logsource: {category: webserver}

detection:

selection: {cs_method: GET, cs_uri_stem|re: '^/api/v1/orders/\d+'}

timeframe: 1m

condition: selection | count() by c_ip > 15

level: high

4. MANDATORY APPROVAL GATE — AWAITING STAKEHOLDER SIGN-OFF

This document concludes Phase 1 of the assessment. Per enterprise Blue Team operating principles, no application code modifications or remediation scripts will be executed until authorized by the technical lead or system owner.

Next Step: Provide written approval to proceed to Phase 2 (Defensive Remediation & Retesting).